CÔNG TY TNHH CÔNG NGHỆ AN PHÁT DIGITAL

03 CHINH SACH BAO MAT THONG TIN

1. Nguyên tắc chung

Thông tin chỉ được truy cập theo nhu cầu công việc và quyền tối thiểu. Nhân viên chịu trách nhiệm với dữ liệu mình tạo, nhận, chia sẻ và lưu trữ. Việc tiện lợi không phải lý do để bỏ qua kiểm soát bảo mật.

2. Phân loại dữ liệu

Dữ liệu Công khai có thể phát hành sau phê duyệt. Dữ liệu Nội bộ chỉ dùng trong công ty. Dữ liệu Mật gồm hợp đồng, tài chính, mã nguồn và dữ liệu khách hàng. Dữ liệu Hạn chế gồm mật khẩu, khóa bí mật, hồ sơ định danh và dữ liệu sức khỏe; chỉ nhóm được ủy quyền được xử lý.

3. Mật khẩu và xác thực

Mật khẩu phải dài ít nhất 12 ký tự, không dùng lại với tài khoản cá nhân và phải lưu trong trình quản lý mật khẩu được công ty cấp. MFA bắt buộc cho email, VPN, Git và hệ thống quản trị. Không cung cấp mã OTP cho bất kỳ ai, kể cả người tự nhận là IT.

4. Thiết bị và làm việc từ xa

Máy công ty phải bật mã hóa ổ đĩa, khóa tự động sau năm phút và cài phần mềm quản lý thiết bị. Chỉ truy cập hệ thống nội bộ qua VPN khi ngoài văn phòng. Không sử dụng máy tính công cộng hoặc Wi-Fi không tin cậy để xử lý dữ liệu Mật và Hạn chế.

5. Chia sẻ và lưu trữ

Tài liệu công việc lưu trên kho được phê duyệt, không đưa lên drive cá nhân. Khi gửi ra ngoài phải kiểm tra người nhận, phạm vi, thời hạn liên kết và thỏa thuận bảo mật. Dữ liệu Hạn chế không được gửi qua email thông thường nếu chưa mã hóa.

6. Phát triển phần mềm an toàn

Không ghi khóa API hoặc mật khẩu vào mã nguồn. Pull request cần được review, thư viện phải quét lỗ hổng và môi trường sản xuất tách khỏi môi trường thử nghiệm. Dữ liệu thật không được sao chép sang môi trường phát triển nếu chưa ẩn danh và phê duyệt.

7. Báo cáo sự cố

Mất thiết bị, gửi nhầm dữ liệu, nghi ngờ phishing hoặc truy cập trái phép phải báo Service Desk số máy lẻ 115 hoặc security@anphat.example trong vòng 30 phút. Không tự xóa bằng chứng. Nhóm An toàn thông tin phân loại, cô lập, điều tra và thông báo các bên liên quan.

8. Nghỉ việc và xử lý vi phạm

Trong ngày làm việc cuối, nhân viên bàn giao dữ liệu, trả thiết bị và bị thu hồi quyền truy cập. Không được giữ bản sao tài liệu sau khi nghỉ việc. Vi phạm có thể dẫn tới thu hồi quyền, xử lý kỷ luật, bồi thường hoặc thông báo cơ quan có thẩm quyền tùy mức độ.